April 1, 2026

HSE Observation Platform

Security, Data Storage & Privacy Statement

TABLE OF CONTENTS

1. About FLAGIT 2
2. Where Is Your Data Stored? 2
Cloud Infrastructure 2
Data Centres 2
Backups 2
File Storage (Photos) 2
3. Security Architecture 3
Authentication 3
Invite-Only Access 3
Role-Based Access Control (RBAC) 3
Row-Level Security (RLS) 3
Data Isolation 3
Encryption 4
Infrastructure Security 4
4. Data Privacy 4
What Data We Collect 4
What We Do NOT Collect 4
Data Ownership 4
Data Retention 5
GDPR Compliance 5
5. AI Features 5
6. Compliance & Standards 5
7. Incident Response 6
8. Availability & Uptime 6
9. Contact & Data Requests 6
10. Summary for Decision Makers 6

1. About FLAGIT

FLAGIT is a cloud-based HSE (Health, Safety & Environment) observation and compliance tracking platform designed for field officers, HSE managers, and site supervisors operating in construction, oil & gas, manufacturing, and industrial environments.

FLAGIT enables real-time observation reporting, corrective action tracking, NCR generation, and team collaboration — accessible from any device, anywhere on site.

2. Where Is Your Data Stored?

Cloud Infrastructure

All FLAGIT data is stored on **Supabase**, a world-class enterprise database platform built on **PostgreSQL** — the same database technology trusted by organisations including Apple, Instagram, and the International Space Station.

Data Centres

- Supabase operates on **Amazon Web Services (AWS)** infrastructure
- Data is hosted in **highly available, redundant data centres**
- Default region: **US East (Virginia)** — regional options available on request
- Data is replicated across multiple availability zones ensuring **zero single point of failure**

Backups

- **Automatic daily backups** are performed and retained for a minimum of 7 days
- **Point-in-time recovery** is available — data can be restored to any specific moment
- Backups are stored in geographically separate locations from primary data
- No data is ever permanently lost due to hardware failure

File Storage (Photos)

- Observation and close-out photos are stored in **Supabase Storage**
- All files are stored in **private, access-controlled buckets**

- Photos are only accessible to authenticated members of the relevant project
- Files are encrypted at rest and in transit

---

3. Security Architecture

Authentication

- FLAGIT uses **email-based One-Time Password (OTP)** authentication
- No passwords are stored — eliminating password breach risks entirely
- Every login requires a fresh 6-digit code sent to the user's verified email
- Sessions are managed with industry-standard **JWT (JSON Web Tokens)** with automatic refresh and expiry

Invite-Only Access

- FLAGIT operates an **invite-only access model**
- No user can self-register and access project data without explicit approval from a project administrator
- Each invite is tied to a specific email address and project
- Invites expire and can be revoked instantly by administrators

Role-Based Access Control (RBAC)

FLAGIT enforces strict role-based permissions at every level:

Role	Capabilities
Admin	Full access — create, edit, delete observations, manage team members, send invites, revoke access
Member	Create and edit own observations, add comments, update status, view all project observations

Row-Level Security (RLS)

- Every database table is protected by **Supabase Row-Level Security policies**
- These policies are enforced at the **database level** — not just the application level
- Even if the application code were compromised, the database would still enforce access rules
- No user can ever access data from another organisation's project

Data Isolation

- Each organisation's data is **completely isolated** at the database level

- Project A cannot see, access, or query any data belonging to Project B
- This isolation is enforced by cryptographic user identity (UUID) — not just application logic

Encryption

- All data in transit is encrypted using **TLS 1.2 / TLS 1.3** (HTTPS)
- All data at rest is encrypted using **AES-256** encryption
- SSL certificates are issued and automatically renewed by **Let's Encrypt**
- The FLAGIT domain (getflagit.com) enforces **HTTPS-only** access — HTTP connections are automatically redirected

Infrastructure Security

- FLAGIT is hosted on **Vercel** — a SOC 2 Type II certified platform
- Vercel operates a global edge network with **DDoS protection** built in
- No direct database access is exposed to the public internet
- All API keys and credentials are stored as environment variables — never in source code

---

4. Data Privacy

What Data We Collect

FLAGIT collects only the minimum data necessary to operate the platform:

- **Account data:** Full name, email address, job role
- **Observation data:** Category, location, description, photos, timestamps, recommendations
- **Activity data:** Login timestamps, observation status updates, comments
- **Presence data:** Online/offline status (stored temporarily, not used for tracking)

What We Do NOT Collect

- No payment card information
- No biometric data
- No location/GPS tracking
- No device identifiers beyond what the browser provides
- No data is sold or shared with third parties for advertising purposes

Data Ownership

- **Your organisation owns your data** — at all times

- FLAGIT does not claim ownership of any observation data, photos, or reports generated on the platform
- Data export is available on request

Data Retention

- Active project data is retained for the duration of the subscription
- Upon account closure, data is retained for 30 days before permanent deletion
- Users may request immediate deletion of their data at any time

GDPR Compliance

FLAGIT is designed with GDPR principles in mind:

- **Lawful basis:** Data is processed only to deliver the contracted service
- **Data minimisation:** Only necessary data is collected
- **Right to access:** Users can request a copy of their data at any time
- **Right to erasure:** Users can request deletion of their personal data
- **Data portability:** Observation data can be exported in standard formats

---

5. AI Features

FLAGIT includes an optional AI-powered recommendation feature (**Ask FLAGIT AI**) that suggests corrective actions based on observation details.

- AI suggestions are powered by **Groq** using the **LLaMA 3** language model
- **No observation data is stored or used for AI training** by the AI provider
- AI queries are stateless — each request is independent with no memory of previous queries
- Use of the AI feature is optional — all fields can be completed manually
- The AI API key is stored in the user's browser local storage only — never transmitted to FLAGIT servers

---

6. Compliance & Standards

FLAGIT's infrastructure providers maintain the following certifications:

Provider	Certifications
Supabase / AWS	SOC 2 Type II, ISO 27001, ISO 27017, ISO 27018, GDPR compliant
Vercel	SOC 2 Type II, GDPR compliant

Provider	Certifications
Groq (AI)	SOC 2 Type II

---

7. Incident Response

In the event of a security incident:

- Affected organisations will be notified within **72 hours** of discovery
- A full incident report will be provided including scope, impact, and remediation steps
- FLAGIT maintains an incident response plan aligned with **ISO 27035** guidelines

---

8. Availability & Uptime

- FLAGIT targets **99.9% uptime** for all production services
- Real-time status monitoring is in place for all critical components
- Supabase maintains a published status page at **status.supabase.com**
- Vercel maintains a published status page at **www.vercel-status.com**

---

9. Contact & Data Requests

For any security concerns, data access requests, or privacy enquiries:

FLAGIT Support 📧 support@getflagit.com 🌐 getflagit.com 📋 Data requests are acknowledged within 48 hours and fulfilled within 30 days

---

10. Summary for Decision Makers

Concern	FLAGIT Answer
Where is data stored?	AWS-backed Supabase cloud — enterprise grade
Is data backed up?	Yes — daily automatic backups with point-in-time recovery
Who can access our data?	Only invited members of your project — enforced at database level
Can other companies see our data?	No — complete cryptographic isolation between organisations
Is data encrypted?	Yes — AES-256 at rest, TLS 1.3 in transit

Concern	FLAGIT Answer
Is it GDPR compliant?	Yes — designed with GDPR principles
What if there's a breach?	72-hour notification, full incident report
Do you sell our data?	Never
Who owns the data?	Your organisation — always

This document was prepared by FLAGIT and is accurate as of April 2026. For the most current version please visit getflagit.com or contact support@getflagit.com